MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 066 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

COLUMN · ACCESS CONTROL

Separation of Duties With Ten People Is a Review, Not a Second Hire

NIST 800-171 3.1.4 asks a small contractor to separate duties it lacks the staff to split. The answer is named pairs, separate accounts and outside review.

BY MAXINE

READING TIME · 5 MIN

SEPARATION-OF-DUTIES · ACCESS-CONTROL · LEAST-PRIVILEGE · NIST-800-171 · CMMC

Requirement 3.1.4 of NIST SP 800-171 reads as if it were written for organizations with enough people to split a job in two, and it lands on defense subcontractors with ten. It asks that the duties of individuals be separated "to reduce the risk of malevolent activity without collusion," and in a shop where one person runs the domain, approves the purchases and reads the logs, the instinct is to file it as a requirement for larger companies and move on. That instinct is wrong on the scoresheet and wrong on the risk. Read through its assessment objectives, the requirement does not ask for headcount. It asks for a short list, a second login and a habit, and a ten-person shop can produce all three.

The objectives, from NIST SP 800-171A, are brief. The duties of individuals that require separation are defined (3.1.4[a]). Those defined duties are separated (3.1.4[b]). Separate accounts are established for individuals whose duties and accesses must be separated (3.1.4[c]). The first is the easiest to skip, and it is the one entirely in their control, because the organization chooses which duties need splitting. It does not have to catalog every task in the company. It has to name the pairs where one person holding both halves would let a single bad actor, or a single compromised account, do harm and then hide it.

In a small enclave those pairs are few. Granting access, and reviewing who has access. Administering a system, and reviewing its audit logs. Changing a configuration, and approving the change. Requesting a payment and releasing it, where the finance system sits inside the boundary. Four lines make a definition an assessor can read, and the examine list for 3.1.4 asks for exactly that kind of artifact: a list of divisions of responsibility and separation of duties, read beside the system access authorizations and the system audit logs. A shop that writes the four lines into its system security plan has met 3.1.4[a] at a cost of an afternoon.

The second objective is where headcount seems to bite, and the useful move there is to separate the act from its review rather than the person from the job. Ten people may include only one who can administer the server. They almost certainly include someone else who can read a report of what that administrator did. The owner, the program manager, or an outside provider reading the administrator's privileged actions on a fixed schedule turns a single point of trust into a pair. Whether an assessor accepts review as separation under 3.1.4[b] is a judgment, not a rule this column can promise, so the plan should say it outright: the shop is too small to split the role, this person reviews it, this often, and this record shows each review happened. A stated compensating arrangement gives the assessor something to test. A silent gap gives them nothing.

The requirement does not ask a small shop to hire a second administrator. It asks that the first one never be the only person who sees what was done.

That review needs something to read, which is where a neighboring requirement does the work. Requirement 3.1.7 asks that non-privileged users be prevented from executing privileged functions and that the execution of privileged functions be captured in audit logs (3.1.7[c] and [d]). A shop that meets 3.1.7 already holds the record its reviewer needs. One that does not has appointed a reviewer with nothing to review. What an assessor expects of the logs themselves ran in an earlier issue on 3.3.1, and the same logs serve both requirements.

FIELD COPY
ISSUE Nº 066
SEPARATION OF DUTIES

3

ASSESSMENT OBJECTIVES IN 3.1.4, WHICH ASK THAT DUTIES BE DEFINED, SEPARATED, AND GIVEN SEPARATE ACCOUNTS

1

SPRS POINT FOR 3.1.4, WHICH IS NOT AMONG THE REQUIREMENTS BARRED FROM A LEVEL 2 POA&M

4

OBJECTIVES IN 3.1.7, THE NEIGHBORING REQUIREMENT THAT PUTS PRIVILEGED FUNCTIONS IN THE AUDIT LOG

◆ ABOUT MACZINE

Written, reviewed and versioned in the open — published from Git, reviewed like code.

The third objective is the cheapest to meet and the easiest to fail without noticing. An administrator who reads email, browses the web and promotes users from the same login has no separation at the account level, whatever the policy says. A daily account and a separate privileged account for the same person is the floor. It is what lets the 3.1.7 audit trail tell administrative acts from ordinary work, and it is what 3.1.4[c] asks for in nearly so many words. Shared administrator logins fail the objective from the other side: a log entry for an account five people use separates no one, because it identifies no one.

An outside provider changes the shape of the problem but not the obligation. Where a managed service provider holds the administrative role, the shop's own staff can be the reviewers, and the division of responsibility belongs in both the plan and the provider's contract, a question MacZine took up in its column on who owns a CMMC program. The arrangement to watch for is the provider that both administers the enclave and produces the only report of its own administration. That is the same unseparated pair, moved off site and billed monthly.

None of this is urgent in the narrow sense. Requirement 3.1.4 is worth 1 point under the DoD Assessment Methodology and is not among the six 1-point requirements barred from a Level 2 POA&M, so a shop that finds it unmet can carry it and close it. That is a reason to fix it calmly, not a reason to skip it, because the risk it addresses does not scale down with the company. A ten-person firm has fewer people who could misuse an administrator's reach, and fewer still who would notice if one did. The four-line list and the second account are a one-time job. The review is the part that can lapse quietly in a busy month, and a program that wants a second pair of eyes on whether its access-control family holds up can start at /readiness. Ten people can separate duties. What they cannot do is assume that someone else is already reading the log. ◆